

- **Integrity:** This term encompasses the following two interrelated concepts:
  - **Data integrity:** It ensures that protected information is not changed by unauthorized users. The information and programs are modified only by the authorized entities.
  - **System integrity:** It promises that a system performs its intended function without any degradation due to changes or disruptions in its internal or external environments.
- **Availability:** It assures that the system works in time to perform its designated or required function without denying the services to the authorized users.

### The Challenges of Network and Computer Security

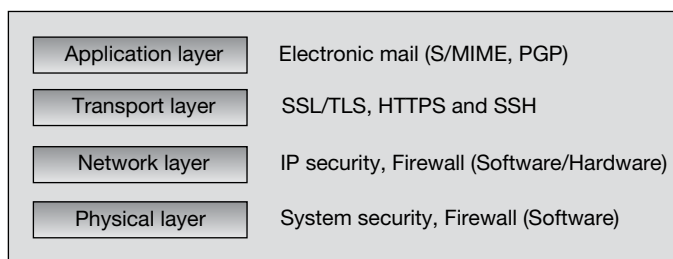
The following are the challenges of network and computer security:

1. It is considered that confidentiality, authentication, non-repudiation and integrity are the major security requirements. But in practical cases, it is quite complex to meet those requirements.
2. During the development of security mechanisms or algorithms for potential attacks, the attackers look at the problem in a totally different way and succeed by designing efficient attacks using an unexpected weakness in the mechanism.
3. One of the necessary challenges is that the place in which the security mechanism is to be implemented is crucial. Moreover, the layer in which the security mechanism is to be implemented is also a critical challenge in order to increase the security level in the network applications.
4. The secrecy of the transmitted information (e.g. an encryption key) depends on communication protocols. The behaviour of communication protocols may complicate for developing the security mechanisms. For example, proper functioning of the security mechanism requires time limits for data transmission. However, some of the protocols may introduce unpredictable delays and hence they would make time limits worthless.
5. There is always a battle between a perpetrator who tries to find gaps and the designer who tries to fill the gaps in the computer and network security. The attacker always has a greater advantage to find a weakness, but the designer is required to find and eradicate all limitations to obtain perfect security.
6. It is difficult to provide security requirements in today's overloaded web environment.

## 1.3 THE OPEN SYSTEMS INTERCONNECTION SECURITY ARCHITECTURE

As known earlier, the open systems interconnection (OSI) security architecture consists of seven layers, namely physical layer, data link layer, network layer, transport layer, session layer, presentation layer and application layer. Among these seven layers, security is concerned only in the four layers namely, physical layer, network layer, transport layer and application layer. OSI security architecture is depicted in Figure 1.2. Application layer security mechanisms include electronic mail (S/MIME, PGP) security which is briefly explained in Chapter 13.

Web security is focused on the transport layer that concentrates on SSL/TLS, HTTPS and SSH. Chapter 14 gives the comprehensive explanation about the transport layer security. Network layer security includes IP security and firewall (hardware) which are briefly explained in Chapter 15.



**Figure 1.2** *OSI security architecture*

The system security focus on physical layer which includes malware identification and virus protection. The physical layer security is briefly explained in Chapter 16.

The OSI security architecture is used for organizing the work of providing security. The international telecommunication union (ITU) Telecommunication Standardization Sector (ITU-T) Recommendation X.800 is a United Nations-sponsored agency that defines a systematic approach of security architecture for OSI. Since this architecture was enlarged as an international standard, it is based on its structured definition of services and mechanisms. Computer and communication sellers have enlarged security features for their products and services. Security mechanisms, security services and security attacks are focussed in OSI security architecture and these are briefly explained as follows:

- **Security mechanism:** It is a process which is intended to detect, prevent and recover the stored/transmitted information from the security attack.
- **Security service:** It is a communication service that improves the security of the data processing systems and the information transfer as defined by ITU-T X.800 Recommendation. This service is designed to oppose security attacks, by using one or more security mechanisms.
- **Security attack:** It is the process of breaking or compromising the security of the stored/transmitted information without the knowledge of the sender and the receiver.

## 1.4 SECURITY ATTACKS

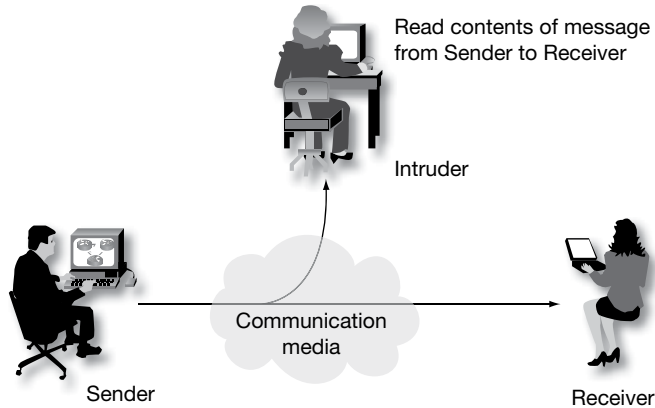
The security attack is an attempt to break the security. There are two types of security attacks, namely passive attack and active attack. In passive attack, the attackers attempt to find out or use information from the system, without affecting the system resources. But in an active attack, an attacker tries to introduce unwanted data into the system as well as potentially change or modify the system resources or affect their operation.

### 1.4.1 Passive Attacks

In passive attacks, message transmissions are monitored by an adversary and thus the goal of the opponent is to acquire or learn information that is being sent in the network channel. Hence, it compromises confidentiality. There are two types of passive attacks. They are (1) release of message contents and (2) traffic analysis.

- **Release of message contents**

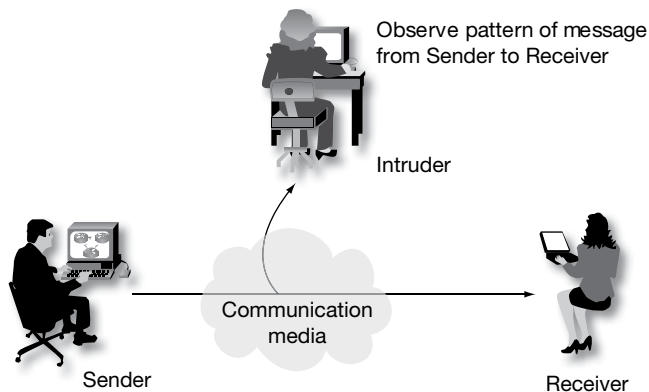
Figure 1.3 shows the process of release of message contents. In this attack, the sender sends sensitive or confidential information to the receiver. But an opponent captures the message and hence learns the contents of these transmissions. Hence, confidentiality of the sensitive or confidential information is compromised.



**Figure 1.3** Release of message contents

- **Traffic analysis**

Figure 1.4 shows the process of traffic analysis. In this attack, the messages are encrypted and cannot be decrypted by the intruder. So if the intruder captures the message, then he/she cannot obtain the message from the transmission. Since the message is encrypted in the sender side, an intruder tries to observe the pattern of the message. From the observation, an intruder could find out the location and identity of the communicating parties and also observe the frequency and length of messages being transmitted. By using this information, an intruder can guess the nature of the communication between the sender and receiver that took place.



**Figure 1.4** Traffic analysis

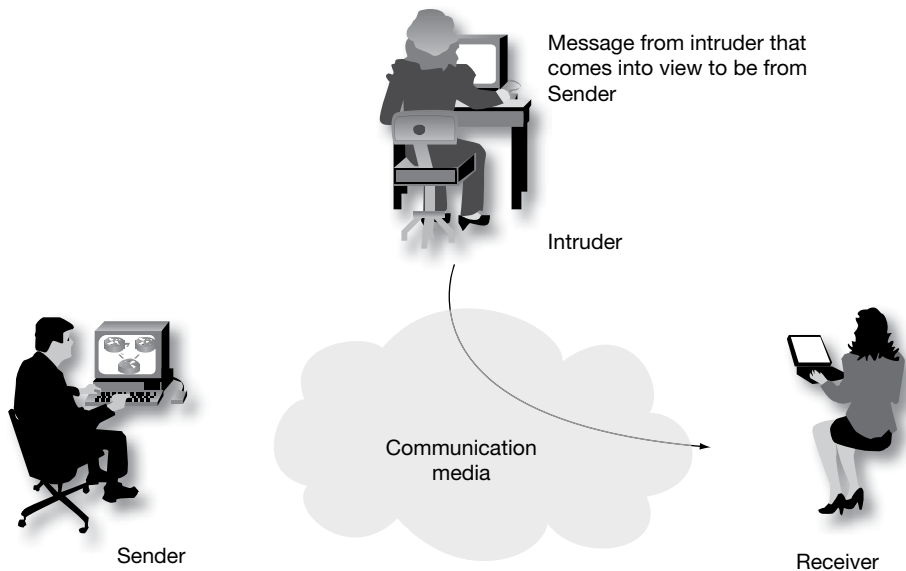
The detection of passive attacks is very hard compared to the detection of active attacks for the reason that they do not engage in the process of altering the transmitted data. Moreover, during the transmission of the messages, neither the sender nor the receiver knows that an intruder has read the messages in this attack. During transmission, passive attacks can be prevented by using strong encryption schemes. Therefore, it is better to prevent the passive attack rather than detecting it.

### 1.4.2 Active Attacks

Active attacks involve some modification of the system resources or the creation of false resources and hence affect their data transmission. So, active attacks compromise the integrity or availability feature. It can be subdivided into four categories: masquerade attack, replay attack, modification of messages attack and DoS attack.

- **Masquerade attack**

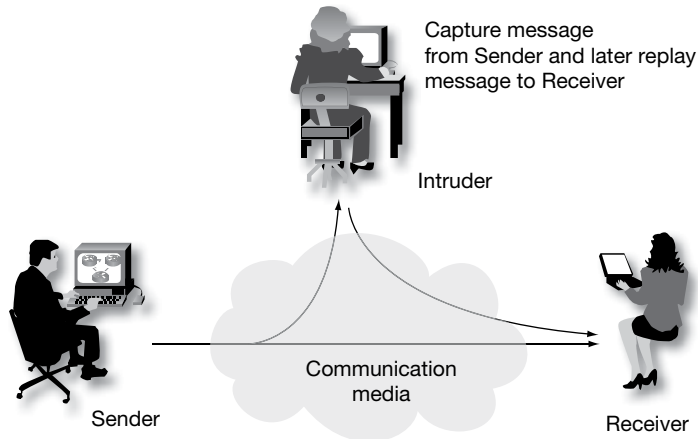
This attack takes place when one user pretends to be a different user to gain unauthorized access through legitimate access identification as shown in Figure 1.5. By using stolen passwords and logons, masquerade attacks can be performed.



**Figure 1.5** Masquerade attack

- **Replay attack**

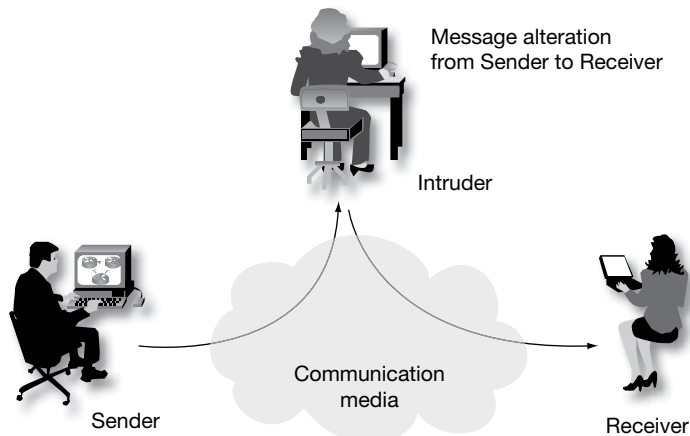
Replay attack is also known as a playback attack in which a valid data is maliciously or fraudulently retransmitted or delayed to produce an unauthorized effect as shown in Figure 1.6.



**Figure 1.6** *Replay attack*

- **Modification of messages attack**

In this attack, an intruder either modifies or alters some portion of a legitimate message and hence it produces an unauthorized effect as depicted in Figure 1.7. For example, the sender sends a message ‘please transfer \$5000 into my account 3048976’ to the receiver. This message can be captured by an intruder and modified as ‘please transfer \$5000 in to my account 1234567’. After seeing this message, the receiver may transfer the amount \$5000 in to the intruder’s account 1234567 who is not an intended user.

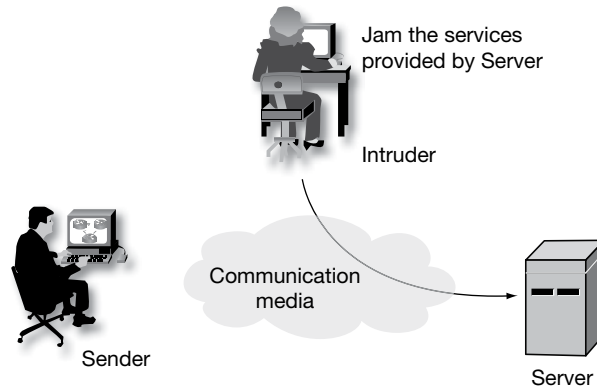


**Figure 1.7** *Modification of messages*

- **Denial of service attack**

In this attack, an intruder may fix a specific target machine (server) and send some unwanted messages to that particular target machine in order to jam the communication media. Using this

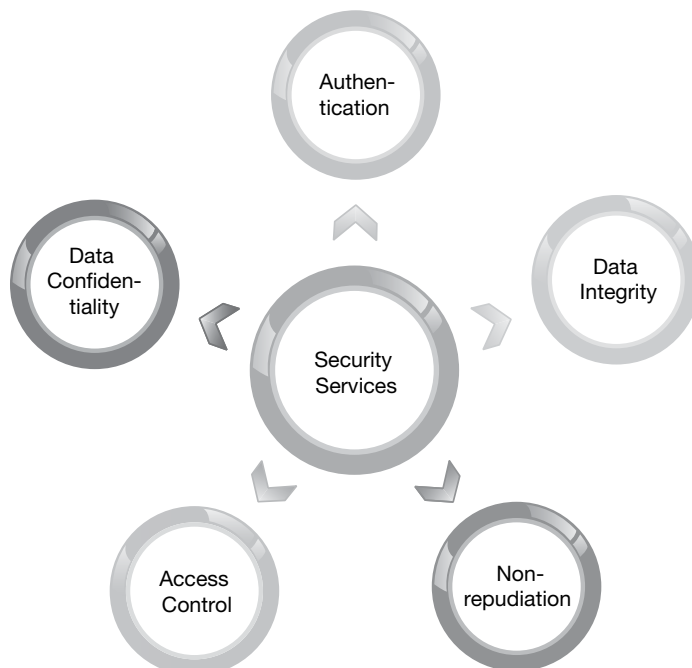
approach, the attackers formulate the network resources to be busy to its rightful users. This kind of attack is shown in Figure 1.8.



**Figure 1.8** DoS attack

## 1.5 SECURITY SERVICES

Based on ITU-T X.800 Recommendation, security services are defined for the system resources and data transfers to provide a specific kind of protection. These services are also divided into five categories. Figure 1.9 shows the different categories of the security services [3].



**Figure 1.9** Categories of security services

### 1.5.1 Authentication

Authentication is a process through which a system verifies the identity of an entity that wishes to access it. The private and public computer networks use logon passwords for performing authentication. Based on the knowledge of the password, it is assumed to promise that the user is authorized. In the initial process, each user assigns a self-declared password for registration. Hence, for each subsequent use, the user must be familiar with and apply the previously declared password. The main drawback in this system is that passwords are often stolen, accidentally disclosed or forgotten. So, digital signatures are used nowadays for authentication purposes. There are two specific types of authentication services defined in X.800:

- **Peer entity authentication:** In an association, if two entities are considered as peer entities, then they are in the same working environment or equivalent working environment of another system. Peer entity authentication is essential in two cases. The first case is the establishment of new connection, or at the time of initiating a secure data transfer. In peer entity authentication, the initiator of connection transfers authentication credentials such as passwords or signatures to another peer entity in order to avoid masquerade and replay attacks.
- **Data origin authentication:** In data origin authentication, the recipients are enabled to verify that messages are originated from the authenticated sender. However, data integrity is not ensured in this technique. This authentication technique is mainly used in E-mail systems.

### 1.5.2 Access Control

In network security, access control is a security service which has the ability to control the user access to the system resources located on a server. This service provides the access rights in which it maintains the information such as, who can access the system resources, under what conditions the user entities can access the system resources, and the list of the resources that the users are allowed to access.

### 1.5.3 Data Confidentiality

Confidentiality conceals the transmitted information from intruder's passive attacks. An intruder may disclose the contents of transmitting information by applying passive attacks. Hence, the transmitted information should be protected when two users communicate with each other over a period of time. The other important feature of confidentiality is the protection of information from the traffic flow analysis. Otherwise, an intruder can observe the source and destination, frequency, length and different aspects of the activity on a correspondence channel.

### 1.5.4 Non-repudiation

Non-repudiation assures that the sender of the message cannot deny the transmitted message to the receiver in the case of dispute or query. Thus, the receiver can prove that the sender is the one who had actually sent the message. Similarly, the sender can also prove that the receiver has actually received the message.

### 1.5.5 Data Integrity

Data integrity is the process that ensures that the data transmitted from the sender to the receiver is not altered or modified by an intruder. It provides the correctness of the transmitted data since this service protects the transmitted data from alteration during communication.

## KEY TERMS

|                   |                   |
|-------------------|-------------------|
| Access control    | Intruder          |
| Active attack     | Masquerade        |
| Authentication    | Non-repudiation   |
| Availability      | Passive attack    |
| Confidentiality   | Replay attack     |
| Data integrity    | Security attacks  |
| Denial of service | Security services |

## SUMMARY

- In network security, **access control** is a security service which has the ability to control the user access to the system resources located on a server.
- **Active attacks** involve some modification of the system resources or the creation of false resources and hence affect their data transmission.
- **Authentication** is a process through which a system verifies the identity of an entity that wishes to access it.
- **Availability** assures that the system works in time to perform its designated or required function without denying the services to the authorized users.
- **Confidentiality** conceals the transmitted information from intruder's passive attacks.
- **Data integrity** is the process that ensures that the data transmitted from the sender to the receiver is not altered or modified by an intruder.
- **Denial of service (DoS)** is an attack in which an intruder may fix a specific target machine (server) and then may send some unwanted messages to that particular target machine in order to jam the communication media.
- **Masquerade** attack takes place when one user makes belief to be a different user to gain unauthorized access through legitimate access identification.
- **Non-repudiation** assures that the sender of the message cannot deny the transmitted message to the receiver in the case of dispute or query.
- In **passive attacks**, message transmissions are monitored by an adversary and thus the goal of the opponent is to acquire or learn information that is being sent in the network channel.
- **Replay attack** is also known as a playback attack in which a valid data is maliciously or fraudulently retransmitted or delayed to produce an unauthorized effect.
- The **security attack** is an attempt to break the security.
- Based on ITU-T X.800 Recommendation, **security services** is defined for the system resources and data transfers to provide a specific kind of protection.

## REVIEW QUESTIONS

1. What is meant by passive attack?
2. What is meant by active attack?

3. What is the difference between passive and active attacks?
4. Give brief explanation about the OSI security architecture.
5. List and briefly explain about different categories of the security services.
6. List and briefly explain about various security attacks.
7. What are the challenges of network and computer security?
8. What is the difference between symmetric encryption and asymmetric encryption?
9. Give some attacks and its corresponding countermeasures in cryptography.

## REFERENCES

1. <http://its.ucsc.edu/security/training/intro.html>
2. Committee on National Security Systems: National Information Assurance (IA) Glossary, CNSS Instruction No. 4009, 26 April 2010.
3. Stallings, William (2007), *Network Security Essentials: Applications and Standards* (Upper Saddle River, NJ: Prentice Hall)– pp. 413.